BÀI KIỂM TRA THƯỜNG XUYÊN 2

ĐẢM BẢO CHẤT LƯỢNG PHẦN MỀM

PHẦN II. BÁO CÁO CÁ NHÂN

ĐỀ TÀI

Đảm bảo chất lượng cho dự án ứng dụng web quản lý dự án Vira

BÁO CÁO CÁ NHÂN

Thiết lập và vận dụng hệ thống đảm bảo chất lượng phần mềm trọng tâm rà soát mã nguồn

Sinh viên: Trần Đức Ngọc

Mã sinh viên: 2023602056

Lớp: 2023DHKTPM02 Nhóm: 5

Số thứ tự: 045 Mã đề: TX2-10_11_12-045

Nhiệm vụ cá nhân: Rà soát mã nguồn; tập trung vào coding standards, tính bảo trì và phân quyền.

LỜI MỞ ĐẦU

Chất lượng phần mềm chịu ảnh hưởng bởi cách tổ chức mã nguồn, mức độ tuân thủ quy ước lập trình, khả năng bảo trì và việc kiểm soát quyền truy cập. Rà soát mã nguồn giúp phát hiện những điểm chưa phù hợp với yêu cầu và tiêu chuẩn của dự án, qua đó hỗ trợ hạn chế lỗi và tạo thuận lợi cho việc sửa đổi phần mềm.

Vira là ứng dụng web hỗ trợ quản lý dự án và cộng tác công việc theo cấu trúc Workspace – Project – Task/Subtask. Hệ thống cung cấp các chức năng như Kanban, Sprint, phân công công việc và quản lý quyền thành viên. Vì vậy, hoạt động rà soát mã nguồn cần chú ý đến khả năng bảo trì và việc kiểm tra quyền tại backend.

Trong khuôn khổ bài kiểm tra thường xuyên 2 của học phần Đảm bảo chất lượng phần mềm, báo cáo cá nhân này tập trung thiết lập và vận dụng hoạt động SQA cho Vira. Báo cáo lựa chọn Waterfall làm mô hình tham chiếu để bố trí hoạt động kiểm soát theo giai đoạn và ISO/IEC 25010 làm cơ sở lựa chọn đặc tính chất lượng phù hợp với nhiệm vụ.

Nội dung báo cáo gồm lựa chọn mô hình và tiêu chuẩn chất lượng; thiết lập bộ tiêu chuẩn tài liệu SQA; xây dựng quy trình rà soát mã nguồn; và áp dụng checklist vào phạm vi mã nguồn được xem xét. Kết quả được trình bày kèm căn cứ và vị trí minh chứng. Phần rà soát mã nguồn trong tài liệu này là rà soát tĩnh; báo cáo phân biệt rõ bằng chứng trong mã nguồn với các kiểm thử chưa được thực thi trong phạm vi lập báo cáo.

DANH MỤC TỪ VIẾT TẮT

API — Giao diện lập trình ứng dụng (Application Programming Interface)
DTO — Đối tượng truyền dữ liệu (Data Transfer Object)
HTTP — Giao thức truyền tải siêu văn bản (Hypertext Transfer Protocol)
ISO/IEC — Tổ chức Tiêu chuẩn hóa Quốc tế / Ủy ban Kỹ thuật Điện Quốc tế
JWT — Mã thông báo web JSON (JSON Web Token)
SQA — Đảm bảo chất lượng phần mềm (Software Quality Assurance)
UI — Giao diện người dùng (User Interface)

MỤC LỤC

Lời mở đầu.....00
Danh mục từ viết tắt.....00
1. Lựa chọn mô hình phát triển và tiêu chuẩn chất lượng.....00
1.1. Phạm vi và mục tiêu lựa chọn.....00
1.2. Mô hình phát triển Waterfall.....00
1.3. ISO/IEC 25010.....00
1.4. Kết luận phần 1.....00
2. Thiết lập bộ tiêu chuẩn tài liệu SQA.....00
2.1. Mục đích và phạm vi áp dụng.....00
2.2. Cấu trúc chung của tài liệu SQA.....00
2.3. Quy tắc mã và tên tài liệu.....00
2.4. Quy tắc đặt tên file và quản lý phiên bản.....00
2.5. Người soạn, người rà soát và người phê duyệt.....00
2.6. Nội dung, trình bày và bảo mật.....00
2.7. Lưu trữ, truy vết và sử dụng tài liệu.....00
2.8. Kết luận phần 2.....00
3. Quy trình SQA phục vụ rà soát mã nguồn.....00
3.1. Mục tiêu, phạm vi và vai trò.....00
3.2. Đầu vào và đầu ra.....00
3.3. Trình tự thực hiện.....00
3.4. Điều kiện chấp nhận và hồ sơ minh chứng.....00
3.5. Hạn chế khi rà soát cá nhân.....00
4. Checklist rà soát mã nguồn và kết quả áp dụng.....00
4.1. Phạm vi, phương pháp và quy ước đánh giá.....00
4.2. Checklist coding standards và khả năng bảo trì.....00
4.3. Checklist phân quyền và bảo mật.....00
4.4. Checklist tính đúng đắn và toàn vẹn dữ liệu.....00
4.5. Tổng hợp kết quả và phát hiện.....00
4.6. Hướng xử lý và theo dõi.....00
Kết luận.....00
Tài liệu tham khảo.....00

1. LỰA CHỌN MÔ HÌNH PHÁT TRIỂN VÀ TIÊU CHUẨN CHẤT LƯỢNG

1.1. Phạm vi và mục tiêu lựa chọn

Vira là ứng dụng web quản lý dự án và cộng tác công việc theo cấu trúc Workspace – Project – Task/Subtask. Hệ thống hỗ trợ quản lý theo Kanban, Backlog và Sprint; phân công thành viên; bình luận; đính kèm tệp; thông báo và phân quyền. Dự án sử dụng React/Vite ở giao diện, Java/Spring Boot ở backend và MySQL để lưu trữ dữ liệu.

Trong phạm vi cá nhân, mục tiêu là xây dựng cách rà soát có căn cứ, tiêu chí và hồ sơ để kiểm tra phần mã nguồn được giao. Báo cáo ưu tiên các nội dung nêu trong đề bài: coding standards, khả năng bảo trì và phân quyền. Kết luận chỉ áp dụng cho module, file và phiên bản mã nguồn thực sự được kiểm tra.

1.2. Mô hình phát triển được lựa chọn

1.2.1. Mô hình Waterfall

Waterfall (mô hình thác nước) tổ chức hoạt động phát triển theo các giai đoạn tuần tự. Trình tự thường gặp gồm phân tích yêu cầu, thiết kế, lập trình, kiểm thử, triển khai và bảo trì. Đầu ra của một giai đoạn là cơ sở để thực hiện và đánh giá giai đoạn tiếp theo. Theo tài liệu môn học, mô hình này phù hợp hơn với dự án có yêu cầu tương đối rõ ràng và ít thay đổi [1].

1.2.2. Căn cứ lựa chọn Waterfall cho nhiệm vụ cá nhân

Waterfall được lựa chọn làm mô hình tham chiếu vì giúp xác định thời điểm và đầu ra của hoạt động rà soát. Điểm kiểm soát chính được đặt sau khi mã nguồn của phạm vi được giao đã được lập trình và trước khi chuyển sang kiểm thử. Người thực hiện đối chiếu mã nguồn với yêu cầu, thiết kế liên quan, quy ước lập trình và quy tắc nghiệp vụ đã xác định.

Mô hình hỗ trợ lập quy trình có trình tự: xác định phạm vi; chuẩn bị tài liệu đầu vào; rà soát theo tiêu chí; ghi nhận phát hiện; xử lý và kiểm tra lại;

tổng hợp kết quả. Cách trình bày này phù hợp với yêu cầu xây dựng tiêu chuẩn tài liệu, thủ tục SQA và hồ sơ kết quả.

Trong báo cáo, Waterfall là cơ sở tổ chức hoạt động SQA cá nhân, không phải kết luận rằng toàn bộ Vira đã được phát triển theo mô hình này. Các chức năng Agile của sản phẩm như Kanban và Sprint không tự xác định mô hình quy trình phát triển. Khi yêu cầu thay đổi, căn cứ rà soát và tài liệu liên quan cần được cập nhật trước khi đánh giá lại.

1.2.3. Vị trí và quan hệ của hoạt động rà soát

Hoạt động rà soát mã nguồn được đặt sau lập trình và trước kiểm thử. Rà soát giúp phát hiện sai lệch so với yêu cầu và chuẩn đã xác định bằng cách xem xét sản phẩm công việc. Hoạt động này bổ trợ nhưng không thay thế kiểm thử: rà soát xem xét mã nguồn và tài liệu; kiểm thử thực thi phần mềm để đánh giá hành vi trong tình huống cụ thể [2].

1.3. Tiêu chuẩn/mô hình chất lượng được lựa chọn

1.3.1. ISO/IEC 25010

Để thống nhất với Bài 05 của học phần, báo cáo tham chiếu mô hình chất lượng sản phẩm trong ISO/IEC 25010:2011. Mô hình này mô tả các đặc tính chất lượng của sản phẩm phần mềm và chất lượng trong sử dụng; mô hình sản phẩm gồm tám đặc tính: tính phù hợp chức năng, hiệu suất, tính tương thích, khả năng sử dụng, độ tin cậy, bảo mật, khả năng bảo trì và khả chuyển [3]. Do nhiệm vụ cá nhân là rà soát mã nguồn, báo cáo sử dụng mô hình chất lượng sản phẩm làm căn cứ lựa chọn tiêu chí; không đánh giá toàn bộ đặc tính và không tuyên bố sản phẩm đã được chứng nhận ISO/IEC 25010.

1.3.2. Các đặc tính áp dụng vào rà soát mã nguồn

Khả năng bảo trì (Maintainability) được ưu tiên vì nhiệm vụ yêu cầu kiểm tra coding standards và tính bảo trì. Nội dung rà soát gồm cách tổ chức module, mức độ rõ ràng của tên gọi, phân chia trách nhiệm giữa lớp/hàm, khả năng theo dõi luồng xử lý và mức độ thuận lợi khi sửa đổi. Tài liệu môn học

mô tả đặc tính này qua các khía cạnh như tính module, khả năng phân tích, sửa đổi và kiểm thử [3].

Bảo mật (Security) được lựa chọn do Vira có phân quyền ở Workspace và Project. Rà soát tập trung kiểm tra backend có xác thực quyền tại thao tác nhạy cảm hay không, quyền được áp dụng đúng vai trò và phạm vi dữ liệu hay không. Việc chỉ ẩn nút trên giao diện không đủ làm căn cứ kết luận API đã được bảo vệ; cần truy vết tới điểm xử lý phía máy chủ và đối chiếu với quy định quyền của dự án.

Tính phù hợp chức năng (Functional suitability) được dùng để đối chiếu logic mã nguồn với yêu cầu chức năng và quy tắc nghiệp vụ. Người thực hiện xác định yêu cầu tương ứng, vị trí code xử lý và sự phù hợp giữa hai nội dung. Nếu cần khẳng định hành vi khi chạy, kết quả rà soát phải được bổ trợ bằng kiểm thử phù hợp.

Độ tin cậy (Reliability) chỉ được xem xét khi liên quan trực tiếp tới phạm vi. Ví dụ, quy định Vira yêu cầu một số thao tác cập nhật trạng thái, di chuyển, xóa mềm hoặc khôi phục task gửi kèm version hiện tại để hỗ trợ optimistic locking. Nếu các thao tác này thuộc phạm vi, cần kiểm tra việc truyền và xử lý version; kết quả không được khái quát thành đánh giá độ tin cậy toàn hệ thống.

1.3.3. Chuyển mô hình thành tiêu chí có thể kiểm tra

ISO/IEC 25010 cung cấp nhóm đặc tính chất lượng ở mức mô hình. Để áp dụng vào nhiệm vụ cá nhân, mỗi đặc tính được chọn cần chuyển thành câu hỏi kiểm tra, phương pháp đánh giá và yêu cầu minh chứng. Ví dụ dưới đây định hướng việc lập checklist; trạng thái đánh giá chỉ được điền sau khi kiểm tra thực tế.

1.4. Kết luận phần 1

Waterfall được chọn làm mô hình tham chiếu để xác định vị trí, đầu vào và đầu ra của hoạt động rà soát mã nguồn cá nhân. ISO/IEC 25010 được lựa chọn để hình thành tiêu chí chất lượng, tập trung vào khả năng bảo trì, bảo

mật và tính phù hợp chức năng; độ tin cậy được xem xét giới hạn khi liên quan đến thao tác thuộc phạm vi. Đây là cơ sở cho tiêu chuẩn tài liệu và quy trình ở các phần tiếp theo.

2. THIẾT LẬP BỘ TIÊU CHUẨN TÀI LIỆU SQA CHO DỰ ÁN

2.1. Mục đích và phạm vi áp dụng

Bộ tiêu chuẩn tài liệu SQA quy định cách nhận diện, cấu trúc, đặt tên, quản lý phiên bản, rà soát, phê duyệt và lưu trữ tài liệu dùng trong nhiệm vụ cá nhân. Mục tiêu là bảo đảm tài liệu nhất quán, truy vết được và phản ánh đúng phần mã nguồn đã kiểm tra.

Tiêu chuẩn áp dụng cho tài liệu cá nhân phục vụ rà soát mã nguồn Vira: kế hoạch/phạm vi rà soát, quy ước và tiêu chí áp dụng, quy trình rà soát, checklist, phiếu ghi nhận phát hiện và báo cáo kết quả. Nội dung tham khảo bài giảng về tiêu chuẩn tài liệu, quy trình review, checklist và thủ tục QA [4], [5].

2.2. Cấu trúc chung của tài liệu SQA

Mỗi tài liệu cần có khối thông tin kiểm soát gồm mã, tên, phiên bản, ngày ban hành/cập nhật, người soạn, người rà soát/phê duyệt và trạng thái. Phần nội dung cần nêu mục đích, phạm vi, thuật ngữ cần thiết, căn cứ tham chiếu, nội dung chính và lịch sử thay đổi. Checklist hoặc báo cáo phát hiện cần bổ sung mã lần rà soát, module, phiên bản code và minh chứng.

2.3. Quy tắc mã và tên tài liệu

Mã tài liệu sử dụng cấu trúc VIRA-SQA-[LOẠI]-[SỐ THỨ TỰ]. VIRA nhận diện dự án; SQA nhận diện nhóm tài liệu đảm bảo chất lượng; LOẠI mô tả loại tài liệu; SỐ THỨ TỰ là hai chữ số tăng dần. Tên file gồm mã tài liệu, tên rút gọn, phiên bản và ngày cập nhật; không sử dụng tên chung chung hoặc khó phân biệt.

Các mã trong bảng là quy ước đề xuất cho báo cáo này; cần dùng nhất quán giữa kế hoạch, quy trình, checklist, phiếu phát hiện và báo cáo. Nếu biểu mẫu giảng viên đã quy định mã khác thì thay thế đồng bộ.

2.4. Quy tắc đặt tên file và quản lý phiên bản

Tên file sử dụng mẫu VIRA-SQA-[LOẠI]-[SCOPE]_v[MAJOR.MINOR]_[YYYYMMDD].docx. SCOPE là module, chức năng hoặc phạm vi; phiên bản thể hiện lần ban hành/cập nhật; ngày dùng dạng năm-tháng-ngày. Ví dụ: VIRA-SQA-CHK-TASK_v1.0_20261028.docx. Nếu tài liệu lưu trong hệ thống quản lý phiên bản, tên file vẫn cần đủ rõ để nhận diện khi tải riêng.

Phiên bản 1.0 là bản đầu tiên được xác lập làm cơ sở sử dụng. Tăng số MINOR, ví dụ 1.1, khi sửa trình bày hoặc bổ sung giải thích mà không đổi phạm vi/tiêu chí cốt lõi. Tăng số MAJOR, ví dụ 2.0, khi thay đổi đáng kể phạm vi, trách nhiệm, quy trình hoặc tiêu chí. Mọi thay đổi phải cập nhật lịch sử phiên bản. Bản cũ được lưu riêng hoặc giữ lịch sử; không ghi đè làm mất khả năng truy vết.

2.5. Người soạn, người rà soát và người phê duyệt

Người soạn là cá nhân thực hiện báo cáo, chịu trách nhiệm xác định phạm vi, lập tài liệu, kiểm tra tính nhất quán và cập nhật phiên bản. Người rà soát/phê duyệt được xác định theo cơ chế học phần hoặc dự án; có thể là giảng viên, người hướng dẫn hoặc người được phân công. Việc quy định vai trò không đồng nghĩa tài liệu đã được duyệt; trạng thái phải phản ánh thực tế.

Trong rà soát code, tác giả mã nguồn và reviewer là hai vai trò nghiệp vụ khác nhau. Cá nhân thực hiện nhiệm vụ SQA rà soát theo checklist; người phụ trách code tiếp nhận và xử lý phát hiện. Nếu không có người độc lập kiểm tra lại, báo cáo phải nêu hạn chế và áp dụng bước tự rà soát lại.

2.6. Nội dung, trình bày và bảo mật

Tài liệu dùng tiếng Việt cho thuyết minh; thuật ngữ kỹ thuật và tên thành phần mã nguồn được giữ nguyên khi cần chính xác. Thuật ngữ cần được giải thích ở lần xuất hiện đầu tiên nếu có nguy cơ nhầm lẫn. Bảng, hình và checklist cần đánh số, có tên và ghi nguồn khi sử dụng nội dung ngoài dự án.

Nhận định phải phân biệt giữa quy định, đề xuất, quan sát và kết quả đã xác minh. Phát hiện cần mô tả vấn đề, vị trí, căn cứ, ảnh hưởng và hướng xử lý. Không đưa mật khẩu, token, khóa bí mật hoặc dữ liệu cá nhân vào tài liệu; minh chứng cần được che thông tin nhạy cảm.

2.7. Lưu trữ, truy vết và sử dụng tài liệu

Tài liệu được lưu trong thư mục riêng của báo cáo cá nhân hoặc vị trí học phần quy định. Kế hoạch SQA xác định phạm vi; quy ước/tiêu chuẩn cung cấp căn cứ; quy trình quy định cách làm; checklist ghi kết quả từng tiêu chí; phiếu phát hiện theo dõi xử lý; báo cáo tổng hợp kết quả. Mỗi phát hiện phải liên kết với mã tiêu chí, module/chức năng, đường dẫn file, phiên bản code nếu xác định được và trạng thái xử lý.

Trước khi nộp, người soạn kiểm tra mã tài liệu, phiên bản, ngày, tài liệu tham chiếu, tính đầy đủ bảng biểu và sự nhất quán giữa hồ sơ. Tài liệu chưa được giảng viên hoặc người hướng dẫn duyệt phải thể hiện đúng trạng thái.

2.8. Kết luận phần 2

Bộ tiêu chuẩn xác định cấu trúc, cách đặt mã và tên, quản lý phiên bản, vai trò soạn/rà soát/phê duyệt và danh mục tài liệu cần dùng cho nhiệm vụ cá nhân. Liên kết mã và phiên bản giữa các hồ sơ hỗ trợ truy vết từ yêu cầu chất lượng đến tiêu chí, phát hiện, xử lý và kết luận.

3. QUY TRÌNH SQA PHỤC VỤ RÀ SOÁT MÃ NGUỒN

3.1. Mục tiêu

Quy trình được thiết lập nhằm kiểm soát có hệ thống hoạt động rà soát mã nguồn cá nhân; phát hiện sai lệch so với yêu cầu và tiêu chuẩn; ghi nhận

minh chứng; theo dõi xử lý; và kết luận trong phạm vi kiểm tra. Trọng tâm gồm coding standards, khả năng bảo trì và phân quyền; tính phù hợp chức năng hoặc quy tắc kỹ thuật được xem xét khi thuộc phạm vi.

Theo nội dung SQA trong tài liệu môn học, hoạt động chất lượng dựa trên quy trình, tiêu chuẩn, checklist và hồ sơ; rà soát mã nguồn là hoạt động kiểm soát sản phẩm, còn thiết lập và duy trì quy trình thuộc hoạt động đảm bảo chất lượng [2], [4], [5].

3.2. Phạm vi

Quy trình áp dụng cho file và chức năng thuộc nhiệm vụ cá nhân trong Vira. Trước mỗi lần rà soát cần ghi module, chức năng, danh sách file, nhánh/commit hoặc mốc phiên bản, yêu cầu liên quan và nội dung loại trừ. Với trọng tâm phân quyền, ưu tiên điểm kiểm tra quyền ở backend thuộc phạm vi được giao; với trọng tâm bảo trì, xem xét cấu trúc và quy ước mã nguồn của module được chọn.

Nếu người giao nhiệm vụ chỉ định module cụ thể thì phạm vi đó được ưu tiên. Nếu chưa chỉ định, người thực hiện thống nhất phạm vi có thể kiểm tra và ghi vào phiếu rà soát trước khi bắt đầu. Quy trình không mặc định kết quả cho module nào và không đánh giá toàn bộ hệ thống nếu chưa rà soát toàn bộ.

3.3. Vai trò và trách nhiệm

Do đây là tiểu luận cá nhân, người thực hiện chịu trách nhiệm chính về hoạt động SQA. Các vai trò tác giả code, reviewer và người hướng dẫn được nêu để phân định trách nhiệm; tên cá nhân và trạng thái phê duyệt chỉ ghi khi có dữ liệu thực tế.

3.4. Đầu vào

Trước khi rà soát, người thực hiện chuẩn bị các đầu vào sau:

- Phạm vi module/chức năng và danh sách file cần rà soát.
- Mã nguồn tại nhánh, commit hoặc phiên bản có thể nhận diện.
- Yêu cầu chức năng, quy tắc nghiệp vụ và tài liệu thiết kế liên quan nếu có.

- Coding standards, quy định bảo mật và quy tắc phân quyền của dự án.
- Tiêu chí ánh xạ từ ISO/IEC 25010 và checklist đúng phiên bản.
- Phiếu ghi kết quả, mẫu phát hiện và công cụ đọc/tìm kiếm code nếu có sử dụng.

Nếu tài liệu đầu vào không tồn tại hoặc không thể truy cập, người thực hiện ghi nhận thiếu hụt. Trạng thái có thể là "Chưa đủ thông tin"; không chuyển thành Đạt dựa trên suy đoán.

3.5. Trình tự thực hiện

3.5.1. Bước 1 - Khởi tạo và xác định phạm vi

Ghi mã lần rà soát, ngày, phạm vi chức năng/module, file, phiên bản code và nội dung loại trừ. Phạm vi cần đủ nhỏ để mỗi tiêu chí có thể được kiểm tra và minh chứng. Xác định rủi ro trọng tâm theo nhiệm vụ, ưu tiên quyền truy cập, tính toàn vẹn dữ liệu và khả năng bảo trì.

3.5.2. Bước 2 - Chuẩn bị tiêu chí và tài liệu

Thu thập yêu cầu, quy tắc dự án và quy ước mã nguồn; chọn checklist phù hợp. Mỗi tiêu chí thể hiện nội dung kiểm tra, căn cứ, phương pháp đánh giá và loại minh chứng cần lưu. Tiêu chí không áp dụng được đánh dấu và giải thích.

3.5.3. Bước 3 - Rà soát mã nguồn

Đối chiếu mã nguồn với từng tiêu chí: cách đặt tên và cấu trúc; trách nhiệm lớp/hàm; khả năng truy vết luồng xử lý; kiểm tra xác thực và phân quyền ở backend; sự phù hợp với quy tắc nghiệp vụ; và quy tắc kỹ thuật như optimistic locking khi thuộc phạm vi. Với quyền truy cập, lần theo luồng từ endpoint tới service hoặc nơi thực thi chính sách quyền, không chỉ quan sát trạng thái giao diện.

Rà soát tập trung vào phát hiện có thể mô tả và tái kiểm tra. Nếu việc sửa ngay có thể làm mất dấu trạng thái ban đầu, ghi nhận phát hiện trước; sau đó mới xử lý theo phân công và quy trình quản lý thay đổi của dự án.

3.5.4. Bước 4 - Ghi nhận và phân loại phát hiện

Mỗi phát hiện được cấp mã duy nhất, ghi tiêu chí liên quan, mô tả, file/vị trí, căn cứ đối chiếu, ảnh hưởng, mức độ, hướng xử lý và trạng thái. Minh chứng có thể là đường dẫn file, tên lớp/hàm, số dòng, commit hoặc ảnh/log đã loại dữ liệu nhạy cảm.

Đây là thang phân loại đề xuất cho nhiệm vụ cá nhân, không phải mức phân loại được khẳng định là quy định chính thức của ISO/IEC 25010. Người rà soát cần nêu lý do khi phân loại.

3.5.5. Bước 5 - Trao đổi và xử lý phát hiện

Phát hiện được chuyển cho người phụ trách mã nguồn hoặc người giao nhiệm vụ theo cơ chế thực tế. Phản hồi được ghi nhận theo trạng thái: chấp nhận, cần làm rõ, không chấp nhận kèm lý do hoặc hoãn xử lý có nêu rủi ro. Nếu cá nhân trực tiếp sửa code, cần ghi nhận thay đổi và phân biệt trạng thái trước/sau sửa.

3.5.6. Bước 6 - Rà soát lại

Sau khi có thay đổi, kiểm tra lại đúng tiêu chí và phạm vi bị ảnh hưởng. Cập nhật trạng thái thành Đã khắc phục, Chưa khắc phục, Hoãn xử lý/Chấp nhận rủi ro hoặc Đóng không sửa theo quyết định thực tế. Không đóng phát hiện chỉ dựa trên thông báo đã sửa; cần có bằng chứng rà soát lại.

3.5.7. Bước 7 - Tổng hợp và kết thúc

Tổng hợp số tiêu chí Đạt, Không đạt, Không áp dụng/Chưa đủ thông tin; số phát hiện theo mức độ và trạng thái; phát hiện còn mở; giới hạn của lần rà soát. Báo cáo kết luận nêu phạm vi, phiên bản code, checklist và thời điểm sử dụng. Hồ sơ được lưu theo tiêu chuẩn tài liệu tại Mục 2.

3.6. Đầu ra

3.7. Điều kiện chấp nhận và tiêu chí kết thúc

Một lần rà soát hoàn tất về mặt hồ sơ khi phạm vi và phiên bản code được xác định; mọi tiêu chí áp dụng có trạng thái; mỗi mục Không đạt có mô tả và minh chứng; mỗi mục Không áp dụng hoặc Chưa đủ thông tin có lý do; phát hiện có trạng thái xử lý; và kết luận giới hạn trong bằng chứng đã thu thập.

Để đề xuất chuyển phần code đã rà soát sang kiểm thử, không còn phát hiện Nghiêm trọng chưa xử lý trong phạm vi; phát hiện Cao được xử lý hoặc có quyết định chấp nhận rủi ro được ghi nhận; phát hiện còn lại có kế hoạch xử lý. Đây là điều kiện đề xuất cho báo cáo cá nhân và cần điều chỉnh nếu dự án hoặc giảng viên quy định ngưỡng khác. Kết quả không đồng nghĩa với nghiệm thu toàn bộ sản phẩm.

3.8. Minh chứng và kiểm soát hồ sơ

Minh chứng phải đủ để người khác kiểm tra lại kết luận. Hồ sơ ghi ít nhất mã và ngày rà soát; người thực hiện; phạm vi; nhánh/commit hoặc phiên bản; mã và phiên bản checklist; tiêu chí; kết quả; vị trí file/code; phát hiện; hướng xử lý; trạng thái rà soát lại. Ảnh chỉ dùng bổ trợ, không thay thông tin đường dẫn và vị trí truy vết. Dữ liệu nhạy cảm phải được che hoặc loại bỏ.

3.9. Hạn chế của rà soát cá nhân và biện pháp kiểm soát

Rà soát do một cá nhân thực hiện có hạn chế về tính độc lập và nguy cơ bỏ sót do quen thuộc với mã nguồn hoặc diễn giải chủ quan. Để giảm rủi ro, người thực hiện dùng checklist đã xác định trước, đối chiếu từng tiêu chí với căn cứ, lưu vị trí minh chứng, đọc lại phát hiện trước khi kết luận và đề nghị người hướng dẫn xem xét phát hiện nghiêm trọng nếu điều kiện học phần cho phép. Báo cáo cần nêu giới hạn này, không trình bày kết quả như một cuộc kiểm toán độc lập.

3.10. Kết luận phần 3

Quy trình xác định mục tiêu, phạm vi, vai trò, đầu vào, trình tự thực hiện, đầu ra, điều kiện chấp nhận và cách lưu minh chứng cho hoạt động rà soát mã nguồn cá nhân. Quy trình là cơ sở để áp dụng checklist, theo dõi phát hiện và lập báo cáo kết quả. Kết luận chỉ được đưa ra sau khi có minh chứng từ mã nguồn thực tế.

4. CHECKLIST RÀ SOÁT MÃ NGUỒN VÀ KẾT QUẢ ÁP DỤNG

4.1. Phạm vi, phương pháp và quy ước đánh giá

Phạm vi rà soát được xác định theo nhiệm vụ cá nhân và mã nguồn backend của Vira, tập trung vào các luồng Project Member, Project/Workspace authorization và Task update. Các tệp trọng tâm gồm ProjectMemberService.java, ProjectService.java, WorkspaceService.java, TaskAuthorizationService.java, TaskService.java, TaskController.java, các request DTO, BaseEntity.java, SecurityConfig.java và ApiExceptionHandler.java. Quy tắc đối chiếu lấy từ AGENTS.md và DAC_TA_VIRA.md của dự án.

Phương pháp áp dụng là rà soát tĩnh: đọc mã nguồn, lần theo lời gọi giữa controller và service, đối chiếu điều kiện phân quyền, validation, truy vấn theo projectId và quy tắc version. Bằng chứng trong checklist ghi đường dẫn và số dòng để người đọc kiểm tra lại. Tài liệu e2e/roles.spec.js và e2e/platform-flow.spec.js được xem là kịch bản kiểm thử có sẵn trong repository; các kịch bản này không được chạy trong phạm vi lập báo cáo nên không được trình bày như kết quả kiểm thử đạt.

Quy ước đánh giá: Đạt khi mã nguồn có xử lý đáp ứng tiêu chí trong phạm vi xem xét; Không đạt khi thiếu xử lý hoặc có điểm chưa nhất quán cần sửa/xác nhận; Không áp dụng khi tiêu chí nằm ngoài phạm vi, kèm lý do. Mỗi mục Không đạt cần có mức độ, căn cứ và hướng xử lý. Kết quả này phản ánh một lượt rà soát tĩnh trên working tree tại ngày lập báo cáo, không thay thế kiểm thử động, kiểm thử bảo mật hoặc peer review độc lập.

Bảng 4.1. Checklist coding standards và khả năng bảo trì

Mã	Tiêu chí và nội dung kiểm tra	Cách đánh giá	Kết quả	Minh chứng trong dự án	Hướng xử lý nếu không đạt
M01	Mã nguồn được phân chia theo miền nghiệp vụ và lớp API/application/ domain.	Đối chiếu cấu trúc package và các file đại diện.	Đạt	backend/src/ main/java/vn/ vira/ {project,task,workspace}/; AGENTS.md, mục Project Structure.	—
M02	Tên phương thức phản ánh chính xác điều kiện hoặc hành vi mà phương thức thực hiện.	Đọc tên và thân hàm, so sánh với điều kiện kiểm tra thực tế.	Không đạt	TaskAuthorizationService.java: 33–37 chỉ xác nhận tư cách thành viên; TaskService.java:61 gọi hàm tên requireTaskCreator.	Đổi tên thành requireTaskCreationPermission hoặc tên tương đương và cập nhật điểm gọi.
M03	Các phụ thuộc service được khai báo rõ và khởi tạo theo constructor.	Kiểm tra cách khai báo dependency trong service được chọn.	Đạt	ProjectMemberService.java:25 –33 dùng @RequiredArgsConstructor và final fields.	—
M04	Các truy vấn chỉ đọc trong phạm vi mẫu được đánh dấu giao dịch chỉ đọc.	Kiểm tra annotation trên một số phương thức truy vấn.	Đạt	ProjectMemberService.java:34 –41; ProjectService.java:82–98; TaskService.java:94–102.	—
M05	Lỗi xác thực, phân quyền, validation và xung đột dữ liệu được ánh xạ tập trung.	Đối chiếu các handler và định dạng phản hồi lỗi.	Đạt	ApiExceptionHandler.java:16–72 xử lý NotFound, validation, AccessDenied và optimistic locking.	—
M06	Request quan trọng có validation tại DTO và được kích hoạt ở controller.	Đối chiếu ràng buộc DTO với @Valid tại endpoint.	Đạt	CreateTaskRequest.java:12–34; ChangeTaskStatusRequest.java:6–12; MoveTaskRequest.java:7–18; TaskController.java:53–76.	—

Mã	Tiêu chí và nội dung kiểm tra	Cách đánh giá	Kết quả	Minh chứng trong dự án	Hướng xử lý nếu không đạt
M07	API trả response DTO thay vì để lộ trực tiếp entity persistence.	Lần theo kiểu trả về và bước mapping trong service.	Đạt	TaskService.java:88–91 dùng TaskMapper; ProjectMemberService.java:58–65 trả ProjectMemberResponse.	—
M08	Tên package, lớp, phương thức và biến trong mã nguồn dùng tiếng Anh theo quy ước dự án.	Đối chiếu quy ước ngôn ngữ với mã nguồn đã chọn.	Đạt	AGENTS.md, Development Conventions mục 4; các lớp ProjectMemberService, TaskService, TaskAuthorizationService.	—

Bảng 4.2. Checklist phân quyền và bảo mật

Mã	Tiêu chí và nội dung kiểm tra	Cách đánh giá	Kết quả	Minh chứng trong dự án	Hướng xử lý nếu không đạt
S01	API yêu cầu xác thực mặc định, chỉ công khai các endpoint được khai báo rõ.	Đọc cấu hình filter chain và danh sách permitAll.	Đạt	SecurityConfig.java:29–37: auth, health và Swagger được permit; anyRequest authenticated.	—
S02	Truy cập dữ liệu Project được giới hạn cho thành viên còn hoạt động.	Lần theo hàm kiểm tra thành viên trước khi trả project.	Đạt	ProjectService.java:141–150 kiểm tra membership chưa bị removed trước khi trả project đang hoạt động.	—
S03	Danh sách thành viên Project yêu cầu người xem là thành viên của Project đó.	Kiểm tra service trước khi truy vấn danh sách.	Đạt	ProjectMemberService.java:34–41 gọi projectService.requireMember(projectId).	—
S04	Quản lý thành viên chỉ dành cho OWNER/ADMIN; MEMBER không thể mời, đổi vai trò hoặc xóa thành viên.	Kiểm tra guard được gọi trên các thao tác quản lý.	Đạt	ProjectMemberService.java:44–47, 68–75, 88–105 kiểm tra requireAdmin.	—

Mã	Tiêu chí và nội dung kiểm tra	Cách đánh giá	Kết quả	Minh chứng trong dự án	Hướng xử lý nếu không đạt
S05	Không thể gán vai trò OWNER cho thành viên mới hoặc nâng thành viên lên OWNER; không thể xóa/đổi vai trò OWNER.	Đối chiếu kiểm tra đầu vào và xử lý thành viên hiện tại.	Đạt	ProjectMemberService.java:47–49, 77–82, 93–95.	—
S06	Cấu hình, lưu trữ và khôi phục Project chỉ do chủ sở hữu thực hiện.	Lần theo các phương thức update/archive/restore tới kiểm tra owner.	Đạt	ProjectService.java:107–128, 130–137, 168–173.	—
S07	Cấu hình, lưu trữ và khôi phục Workspace chỉ do chủ sở hữu thực hiện.	Lần theo các phương thức update/archive/restore tới requireOwner.	Đạt	WorkspaceService.java:65–87; restore tại dòng 79–80 cũng gọi requireOwner.	—
S08	Sửa task chỉ được phép với OWNER/ADMIN, người tạo hoặc người được giao.	Đọc điều kiện trong TaskAuthorizationService.	Đạt	TaskAuthorizationService.java: 19–30 kiểm tra admin, reporter và assignee.	—
S09	Tìm task theo ID phải giới hạn đồng thời theo Project và trạng thái xóa.	Kiểm tra các truy vấn lấy task theo ID.	Đạt	TaskService.java:231–234 dùng findByIdAndProjectIdAndDeletedAtIsNull.	—
S10	Danh sách Project đã lưu trữ phải áp dụng chính sách hiển thị nhất quán với phạm vi thành viên Project.	So sánh danh sách đang hoạt động và danh sách archived.	Không đạt	ProjectService.java:83–97 lọc dự án đang hoạt động cho workspace owner hoặc project member; dòng 100 chỉ gọi workspaceService.requireMember rồi lấy toàn bộ archived project của workspace.	Xác định chính sách hiển thị archived project; nếu chỉ thành viên Project được xem, áp dụng bộ lọc tương ứng và bổ sung kiểm thử truy cập trái quyền.
S11	Thay đổi trạng thái và di chuyển task yêu cầu version hiện tại.	Đối chiếu request DTO, service và xử lý version.	Đạt	TaskController.java:60–78; TaskService.java:150–181; request DTO có @NotNull version.	—

Mã	Tiêu chí và nội dung kiểm tra	Cách đánh giá	Kết quả	Minh chứng trong dự án	Hướng xử lý nếu không đạt
S12	Xóa mềm và khôi phục task yêu cầu quyền quản trị cùng version hợp lệ.	Kiểm tra guard và so sánh version trước khi đổi trạng thái xóa.	Đạt	TaskService.java:197–219 gọi requireAdmin và kiểm tra version trước khi xóa/khôi phục.	—

Bảng 4.3. Checklist tính đúng đắn và toàn vẹn dữ liệu

Mã	Tiêu chí và nội dung kiểm tra	Cách đánh giá	Kết quả	Minh chứng trong dự án	Hướng xử lý nếu không đạt
D01	Dữ liệu tạo task có ràng buộc cho tiêu đề, loại, ưu tiên và giá trị số.	Đối chiếu annotation trong request DTO.	Đạt	CreateTaskRequest.java:12–34 có NotBlank, NotNull, Size, DecimalMin và Min.	—
D02	Task cha được kiểm tra thuộc cùng Project với task con.	Đọc hàm tra cứu parent theo projectId.	Đạt	TaskService.java:222–229 dùng findByIdAndProjectIdAndDeletedAtIsNull.	—
D03	Sprint gán cho task phải thuộc cùng Project.	Kiểm tra truy vấn Sprint theo sprintId và projectId.	Đạt	TaskService.java:185–191 dùng findByIdAndProjectId; sai phạm ném BusinessException.	—
D04	Không thể chuyển task cha sang DONE khi còn task con chưa hoàn tất.	Kiểm tra điều kiện trước khi cập nhật status.	Đạt	TaskService.java:160–163 kiểm tra task con khác DONE trước khi đổi trạng thái.	—
D05	Xung đột optimistic locking được trả về trạng thái HTTP phù hợp.	Đối chiếu exception phát sinh và handler.	Đạt	BaseEntity.java:27–28 khai báo @Version; ApiExceptionHandler.java:51–56 ánh xạ lỗi sang CONFLICT.	—

4.5. Tổng hợp kết quả và phát hiện

Checklist gồm 25 tiêu chí. Qua rà soát tĩnh, 23 tiêu chí được đánh giá Đạt và 2 tiêu chí Không đạt. Các mục Đạt chỉ xác nhận rằng trong những đoạn mã đã xem có dấu hiệu xử lý phù hợp với tiêu chí; chúng không chứng

minh không còn lỗi ở những luồng chưa được rà soát. Hai phát hiện cần theo dõi gồm sự chưa tương ứng giữa tên requireTaskCreator và hành vi thực tế, cùng sự khác biệt về phạm vi quyền khi liệt kê Project đã lưu trữ.

Đối với S10, căn cứ hiện có cho thấy danh sách Project đang hoạt động phân biệt workspace owner và project member, trong khi danh sách archived chỉ xác thực workspace membership trước khi truy vấn toàn bộ dự án đã lưu trữ. Đặc tả dự án yêu cầu phân quyền theo API và dữ liệu phải được lọc theo quyền, nhưng chưa nêu riêng quy tắc xem archived project. Vì vậy, đây được ghi nhận là Không đạt về tính nhất quán/đủ căn cứ phân quyền, cần người phụ trách nghiệp vụ xác nhận chính sách và điều chỉnh code hoặc tài liệu tương ứng.

Đối với M02, phương thức requireTaskCreator được gọi khi tạo task nhưng thân hàm chỉ kiểm tra thành viên hiện tại trong Project. Điều kiện cho phép hiện tại có thể đúng nếu mọi thành viên Project được phép tạo task; vấn đề được ghi nhận ở tính rõ nghĩa của tên phương thức, không phải khẳng định sai quyền tạo task. Hướng xử lý là đổi tên để phản ánh chính sách cho phép tạo task hoặc bổ sung kiểm tra người tạo nếu ý nghĩa dự kiến là xác nhận một task cụ thể.

Bảng 4.4. Phiếu ghi nhận phát hiện và hướng xử lý

Mã	Phát hiện	Mức độ	Mô tả và căn cứ	Minh chứng	Hướng xử lý	Trạng thái
F-01	M02 - Tên phương thức không khớp hành vi	Thấp	TaskAuthorizationService.requireTaskCreator chỉ xác nhận người dùng là thành viên Project; hàm được gọi trước khi tạo task. Tên hiện tại có thể khiến người bảo trì hiểu nhầm rằng hàm kiểm tra quyền của tác giả task.	TaskAuthorizationService.java:33–37; TaskService.java:58–63.	Đổi tên thành requireTaskCreationPermission hoặc requireProjectMemberCanCreateTask nếu chính sách là mọi thành viên được tạo task. Xác nhận cùng quy tắc với tài liệu yêu cầu.	Mở
F-02	S10 - Phạm vi xem danh sách archived chưa nhất quán	Cao - cần xác nhận chính sách	Danh sách active phân biệt workspace owner và thành viên Project; danh sách archived chỉ xác thực workspace member rồi truy vấn mọi archived Project trong workspace. Nếu quy tắc chỉ cho thành viên Project xem nội dung dự án, logic hiện tại có nguy cơ tiết lộ thông tin dự án đã lưu trữ cho thành viên workspace không thuộc Project.	ProjectService.java:83–100; yêu cầu phân quyền API tại DAC_TA_VIRA.md, mục 2.	Chốt chính sách với người phụ trách; giới hạn truy vấn theo quyền project member hoặc bổ sung ngoại lệ chính thức vào đặc tả; thêm kiểm thử quyền cho cả hai vai trò.	Mở - chờ xác nhận

4.6. Cách xử lý và đóng phát hiện

Phát hiện F-01 có thể được xử lý bằng việc đổi tên phương thức và cập nhật điểm gọi, sau đó rà soát lại các nơi sử dụng để bảo đảm tên mới không

làm thay đổi hành vi phân quyền. Người thực hiện cần xác nhận thay đổi trong mã nguồn hoặc commit trước khi chuyển trạng thái sang Đã khắc phục.

F-02 cần được chuyển tới người có trách nhiệm xác định chính sách truy cập dự án đã lưu trữ. Khi chính sách được thống nhất, cập nhật đặc tả hoặc tài liệu quyền làm căn cứ; nếu phạm vi xem phải theo project membership, sửa service để truy vấn chỉ trả các dự án người dùng được phép xem. Sau đó bổ sung kiểm thử trái quyền và kiểm thử quyền hợp lệ. Cho đến khi có căn cứ và kết quả kiểm tra lại, giữ trạng thái Mở - chờ xác nhận.

Tài liệu e2e/roles.spec.js và e2e/platform-flow.spec.js có các kịch bản về vai trò, truy cập ngoài Project, yêu cầu version và xung đột phiên bản. Đây là bằng chứng rằng test case được mô tả trong repository, không phải bằng chứng các test đã chạy thành công trong lần rà soát này. Sau khi sửa F-02, cần chạy hoặc giao người phụ trách chạy các kịch bản tương ứng và lưu báo cáo thực thi làm minh chứng bổ sung.

4.7. Giới hạn của kết quả checklist

Rà soát được thực hiện trên mã nguồn tĩnh trong phạm vi các lớp backend nêu ở Mục 4.1. Báo cáo không chạy unit test, integration test, E2E, kiểm thử xâm nhập hoặc xác minh hành vi trên môi trường triển khai. Do đó, các đánh giá Đạt không thay thế việc xác minh runtime. Danh sách đường dẫn và số dòng giúp truy vết tại phiên bản mã nguồn được xem xét; khi code thay đổi, số dòng và kết quả cần được rà soát lại.

Việc rà soát do cá nhân thực hiện cũng có hạn chế về tính độc lập. Để giảm rủi ro bỏ sót, checklist được xác định trước, phát hiện được gắn với căn cứ và vị trí cụ thể, còn phát hiện liên quan chính sách quyền được để mở cho đến khi có xác nhận nghiệp vụ và kiểm tra lại.

4.8. Kết luận phần 4

Checklist đã chuyển các yêu cầu về coding standards, khả năng bảo trì, phân quyền và toàn vẹn dữ liệu thành các tiêu chí có cách đánh giá, kết quả, minh chứng và hướng xử lý. Trong 25 tiêu chí rà soát tĩnh, 23 tiêu chí Đạt;

hai phát hiện được ghi nhận để xử lý hoặc xác nhận trước khi đóng. Kết quả là cơ sở cho hoạt động cải tiến và kiểm tra lại trong phạm vi nhiệm vụ cá nhân.

KẾT LUẬN

Báo cáo đã xây dựng căn cứ lựa chọn Waterfall và ISO/IEC 25010, thiết lập bộ tiêu chuẩn tài liệu SQA, mô tả quy trình rà soát mã nguồn và áp dụng checklist vào một phạm vi cụ thể của backend Vira. Các phần này liên kết mục tiêu chất lượng với quy tắc dự án, tiêu chí kiểm tra, hồ sơ kết quả và cách theo dõi phát hiện.

Qua rà soát tĩnh, các luồng được kiểm tra có những cơ chế bảo vệ đáng chú ý như xác thực mặc định, kiểm tra thành viên và vai trò ở service, giới hạn thao tác chủ sở hữu, kiểm tra version và xử lý lỗi tập trung. Báo cáo đồng thời ghi nhận hai điểm cần xử lý: tên một phương thức chưa phản ánh rõ hành vi và chính sách xem Project đã lưu trữ chưa nhất quán giữa các danh sách. Kết luận này giới hạn ở mã nguồn được rà soát và không thay thế kiểm thử động hoặc đánh giá độc lập.

Trong bước tiếp theo, cá nhân cần cập nhật trạng thái phát hiện sau khi có quyết định nghiệp vụ hoặc thay đổi mã nguồn, lưu minh chứng rà soát lại và hoàn thiện các hồ sơ theo phiên bản đã ban hành. Việc duy trì checklist và lịch sử thay đổi giúp các lần rà soát sau có căn cứ thống nhất và dễ truy vết.

TÀI LIỆU THAM KHẢO

[1] Tài liệu học phần Đảm bảo chất lượng phần mềm, “Bài 01. Tổng quan về đảm bảo chất lượng phần mềm”, tài liệu bài giảng do giảng viên cung cấp.

[2] Tài liệu học phần Đảm bảo chất lượng phần mềm, “Bài 02. Các yếu tố và thành phần ảnh hưởng tới hoạt động SQA”, tài liệu bài giảng do giảng viên cung cấp.

[3] Tài liệu học phần Đảm bảo chất lượng phần mềm, “Bài 03. Các hoạt động đảm bảo chất lượng phần mềm”, tài liệu bài giảng do giảng viên cung cấp.

[4] Tài liệu học phần Đảm bảo chất lượng phần mềm, “Bài 05. Chuẩn và mô hình chất lượng”, tài liệu bài giảng do giảng viên cung cấp; mô hình ISO/IEC 25010:2011 được dẫn theo nội dung học phần.

[5] Tài liệu học phần Đảm bảo chất lượng phần mềm, “Bài 07. Hệ thống đảm bảo chất lượng phần mềm”, tài liệu bài giảng do giảng viên cung cấp.

[6] Tài liệu học phần Đảm bảo chất lượng phần mềm, “Bài 08. Thiết lập và vận hành hệ thống đảm bảo chất lượng phần mềm”, tài liệu bài giảng do giảng viên cung cấp.

[7] Vira Project, “AGENTS.md - Project Guidelines”, tài liệu hướng dẫn dự án.

[8] Vira Project, “Đặc tả yêu cầu phần mềm - Vira”, phiên bản 1.0.